AI ACADEMY · LEVEL 2 · GRADE 7 · WEEK 31 · STUDENT LESSON

Permissions and Human Review

Learn to understand, design, build, test and explain AI systems responsibly.

Project: Transparent Book Recommender

THE CONNECTED WEEK

Check the actor. Check the operation. Check the object.

Apply least privilege and place human review before consequential actions.

Keep one habit: Scoped policy → proposed call → two scope checks → decision → evidence and review.

MAIN LESSON · SECTION 1

Who may do what to which record?

> Check operation and object before a call, then preserve the human review boundary.

Your learning goals

I can explain the **mechanism** and terminology of **least privilege** and tool scopes.

I can apply the stated procedure to a new case with a traceable result.

I can identify an assumption or limitation and design a revealing follow-up.

Recall control flow and authority

- Close your notes first. A rough first answer helps us choose the right starting point; it is not a score for your ability.

- Recall Agents and Tools: a valid state transition does not itself authorise an operation. This week, check who may do what to which resource before execution.

Your end goal

By the end, I can enforce **least privilege** by checking operation and object before execution.

<details>
<summary>Privacy extension · Is a name needed?</summary>

Readiness for Privacy and least privilege

Does a duration summary need student names to calculate a total?

> **My readiness explanation**
>
> _____
>
> _____
>
> _____
>
> _____

</details>

<details>
<summary>Earlier wording, alternatives and picture transcripts</summary>

Your learning target

Remember before reading

Without opening the old lesson, explain one key idea from Agents and Tools. Give an example and a mistake that the idea helps you avoid.

Without opening the old lesson, explain one key idea from Prompt Experiments. Give an example and a mistake that the idea helps you avoid.

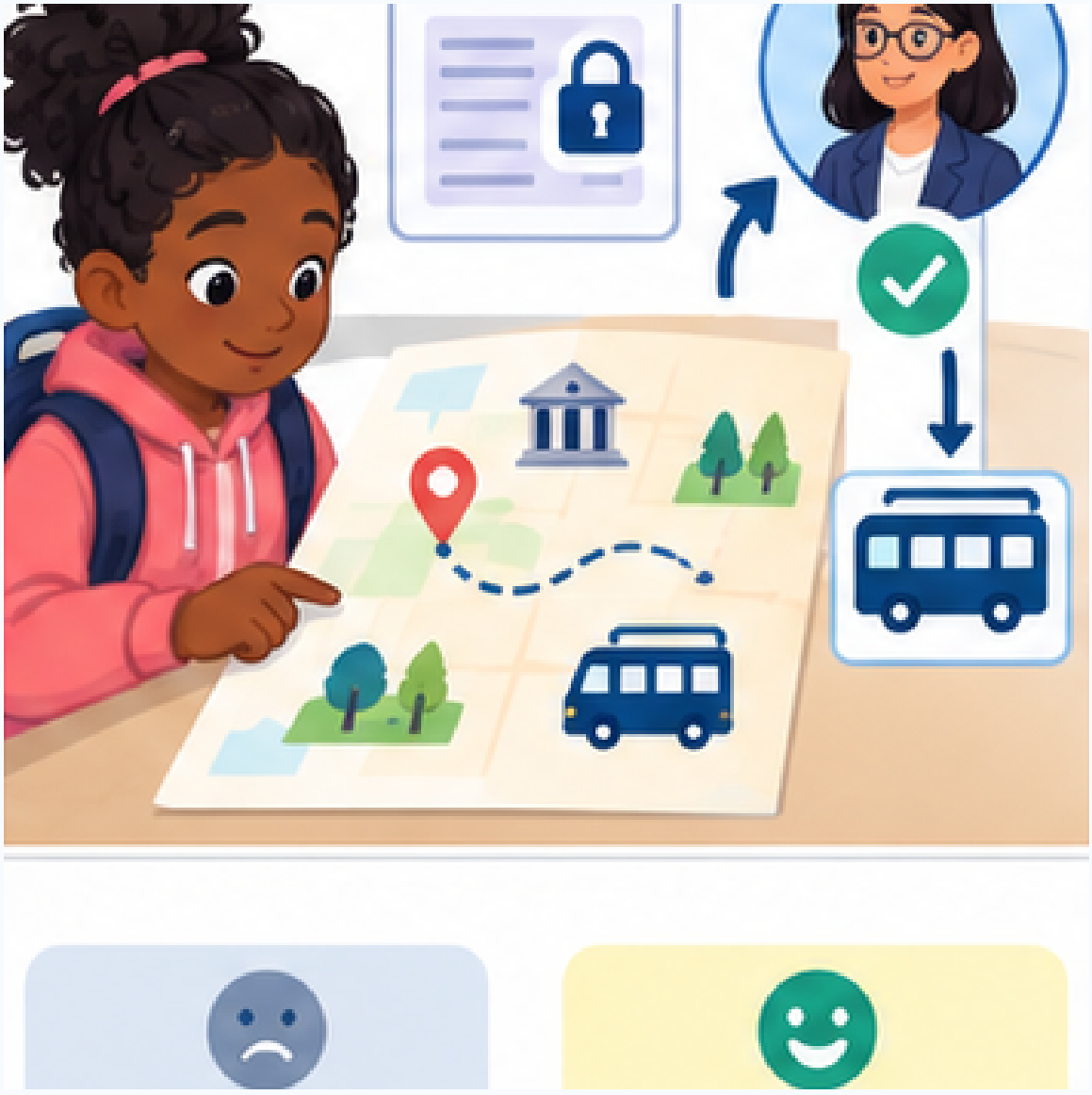
</details>

Without opening the old lesson, explain one key idea from Text as Pieces. Give an example and a mistake that the idea helps you avoid.

After trying, check the relevant lesson or ask your teacher. Change the part of your explanation that the **evidence** shows was wrong.

Week 31: **Permission**s and Human Review

Higher-**consequence** actions need narrower **permission**s and approval.



THINKER MISSION

Place **approval gate**s in a field-trip planning workflow.

Thinker name and date:

> **Write or draw your reasoning and evidence.**

Readiness for the connected explanation

This week’s end goal

MAIN LESSON · SECTION 2

Grant only the capabilities the task requires

> A broad tool name does not specify a permission.

The least-privilege idea

Least privilege grants only capabilities required by the task. Tool access should include resource and operation scope, not merely a broad tool name.

Use invented records and policies

Begin by writing the question the procedure is intended to answer. Identify the information already supplied, the information it will produce and the information still missing.

These are constructed classroom examples; they do not require live accounts, private records or an external service. Do not treat a plausible explanation as a measured outcome.

▼ **Privacy extension · A fictional dashboard**

A fictional class activity dashboard needs category counts, not names or personal messages. Design its data and role **permission**s before collection.

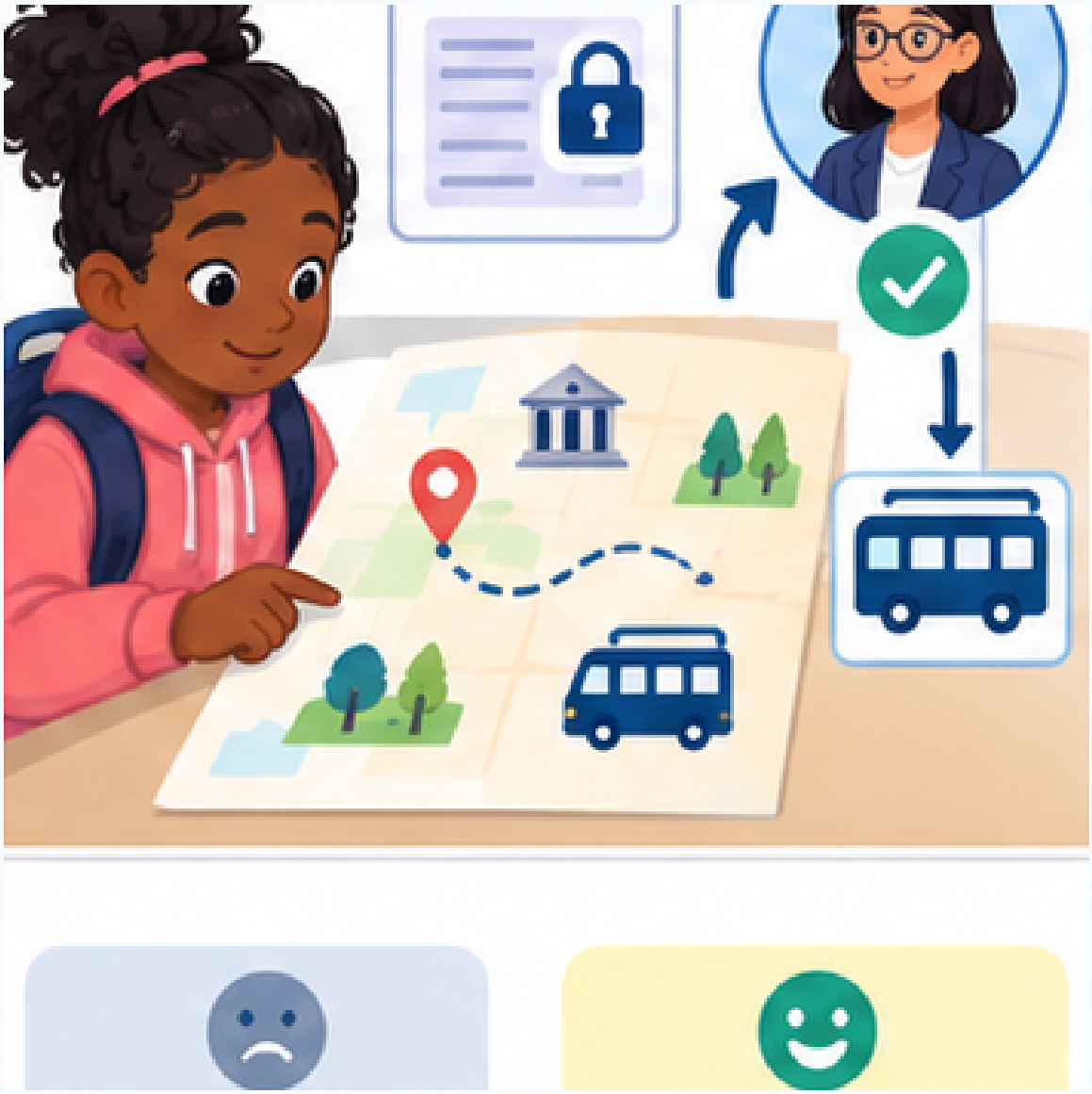
This exercise uses invented data and policy cards; do not change the Academy's actual authentication settings.

▼ Earlier wording, alternatives and picture transcripts

PICTURE STORY

Notice → Predict → Explain

Begin with visible **evidence**. Do not explain more than the picture and information support.



MYSTERY

The learners must use **permission**s and human review to solve a problem. What information do they have? What decision or calculation do they make? What would count as **evidence** that it worked?

Three **observation**s (what you can point to):

> **Write or draw your reasoning and evidence.**

My **prediction** and the clue supporting it:

> **Write or draw your reasoning and evidence.**

A closer explanation

Apply the connected idea: Privacy and least privilege

MAIN LESSON · SECTION 3

Trace a scoped request before execution

> A request must satisfy both the operation and resource restrictions.

The reporting-assistant contract

A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.

Read the policy as separate dimensions

Policy dimension	Reporting assistant
Actor	The stated reporting assistant with its supplied trusted scope
Operation	lookup only
Resource	public-room records only
Other operations or resources	not permitted under this policy

▼ Privacy extension · Trace role permissions in complete code

```
roles = {"student": ["read_summary"],
         "teacher": ["read_summary", "read_review"]}
def allowed(role, action):
    return action in roles.get(role, [])

print(allowed("student", "read_summary"))
print(allowed("student", "read_review"))
print(allowed("unknown", "read_summary"))
```

Follow the evidence

STEP OR CASE	EVIDENCE	MEANING
Student	Read summary	No review notes
Teacher	Read summary and review	Authorized purpose
Unknown role	No listed permissions	Deny by default

Read each row from left to right and connect the evidence to the stated rule.

The toy code prints True, False, False. It models a **permission** decision, not a complete security system.

A real server must verify identity and enforce **authorization** on every protected request; hiding a button in a page is insufficient.

Least privilege means giving each role only the actions needed for its purpose. Read the policy as a table: students may read the approved summary, while teachers may also read the necessary review.

An unknown role gets no listed action. The small function checks this table; it does not establish who a visitor is.

In a real application, the server must verify the session and apply the **permission** check whenever protected data is requested.

Explain the deciding evidence

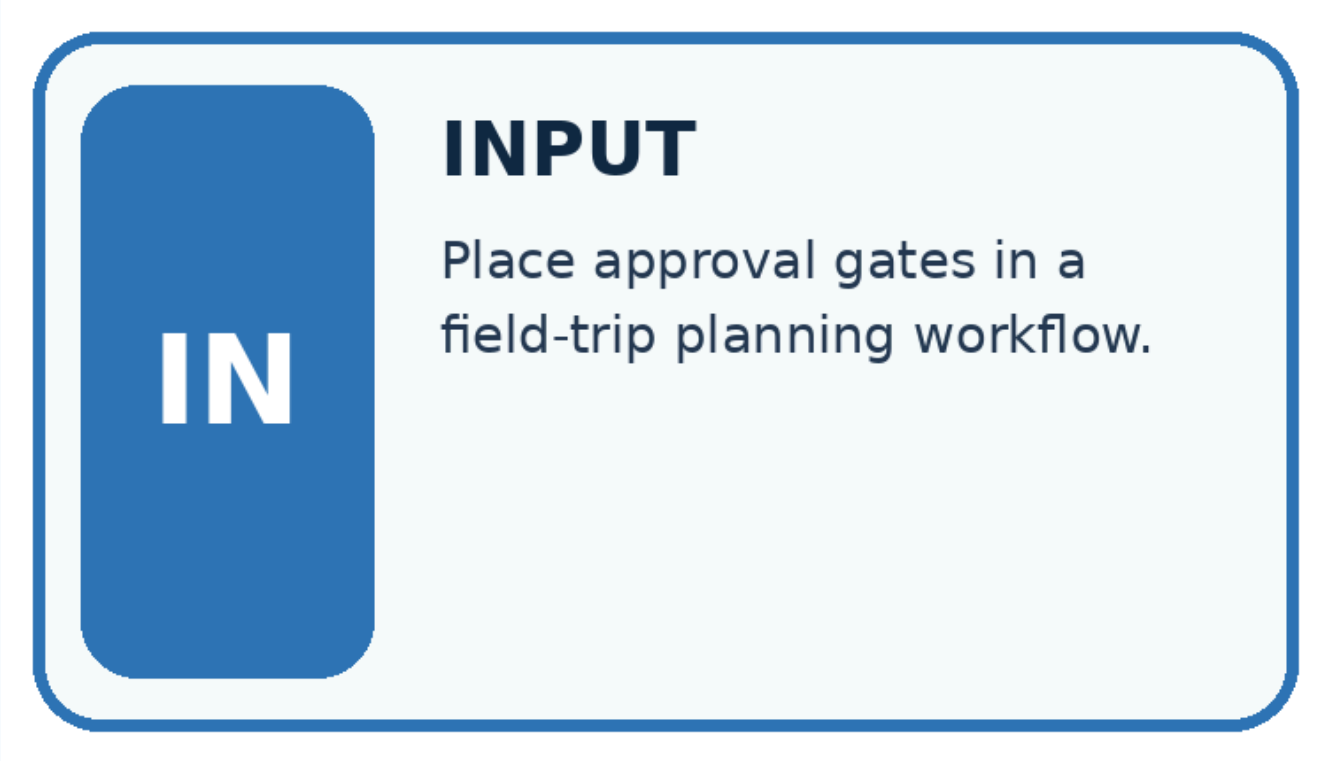
- Point to the **input**, the deciding step and the result in this week's visual. Explain the same step in ordinary words. A picture helps when you can say what each part represents.

▼ **Earlier wording, alternatives and picture transcripts**

VISUAL **MECHANISM**

Input → **Process** → **Output**

Trace the information. At each stage, ask what changed and how you could test it.



↓


PROCESS
Higher-consequence actions need narrower permissions and approval.
↓
OUT
OUTPUT
Place approval gates in a field-trip planning workflow.

Which stage could fail even when the other two are correct? Explain:

> **Write or draw your reasoning and evidence.**

A closer explanation

Least privilege and tool scopes — evidence trace

INPUT AND SCOPE	CHECK OR CALCULATION	CONCLUSION AND LIMIT
Tool token permits lookup(public-room). A proposed call writes teacher notes.	A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes. Check actor, operation and resource before executing a proposed call.	Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

The figure connects this chapter's worked input, declared procedure and result. Read the complete worked reasoning for qualifiers and intermediate steps; the abbreviated labels do not replace that reasoning.

Before applying the procedure, write its units, denominator or decision boundary where relevant. A partner should be able to repeat each step using the same **input**s.

If a required **input** is absent or violates the stated contract, record that condition explicitly instead of quietly replacing it with a convenient value.

Apply the connected idea: Privacy and least privilege

Ask what each role actually needs

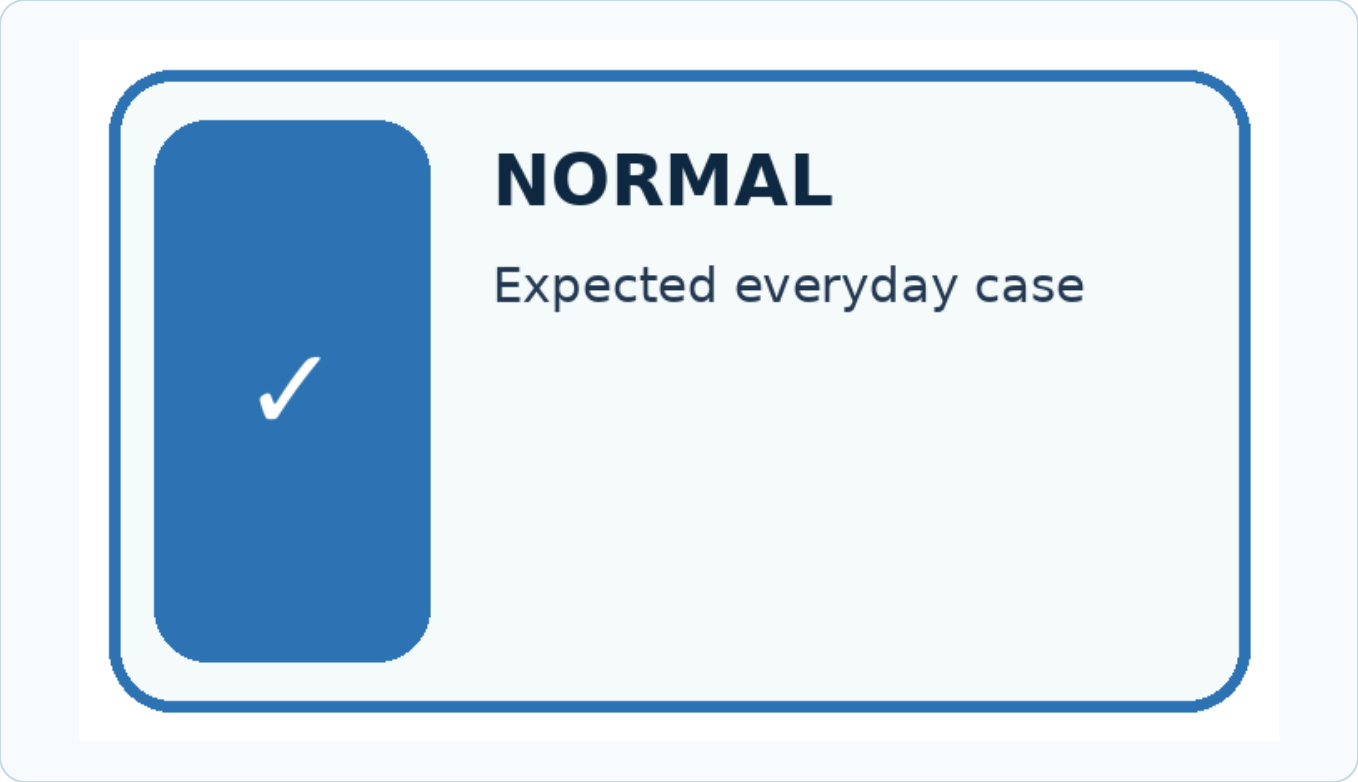
Connect the picture and the explanation

MAIN LESSON · SECTION 4

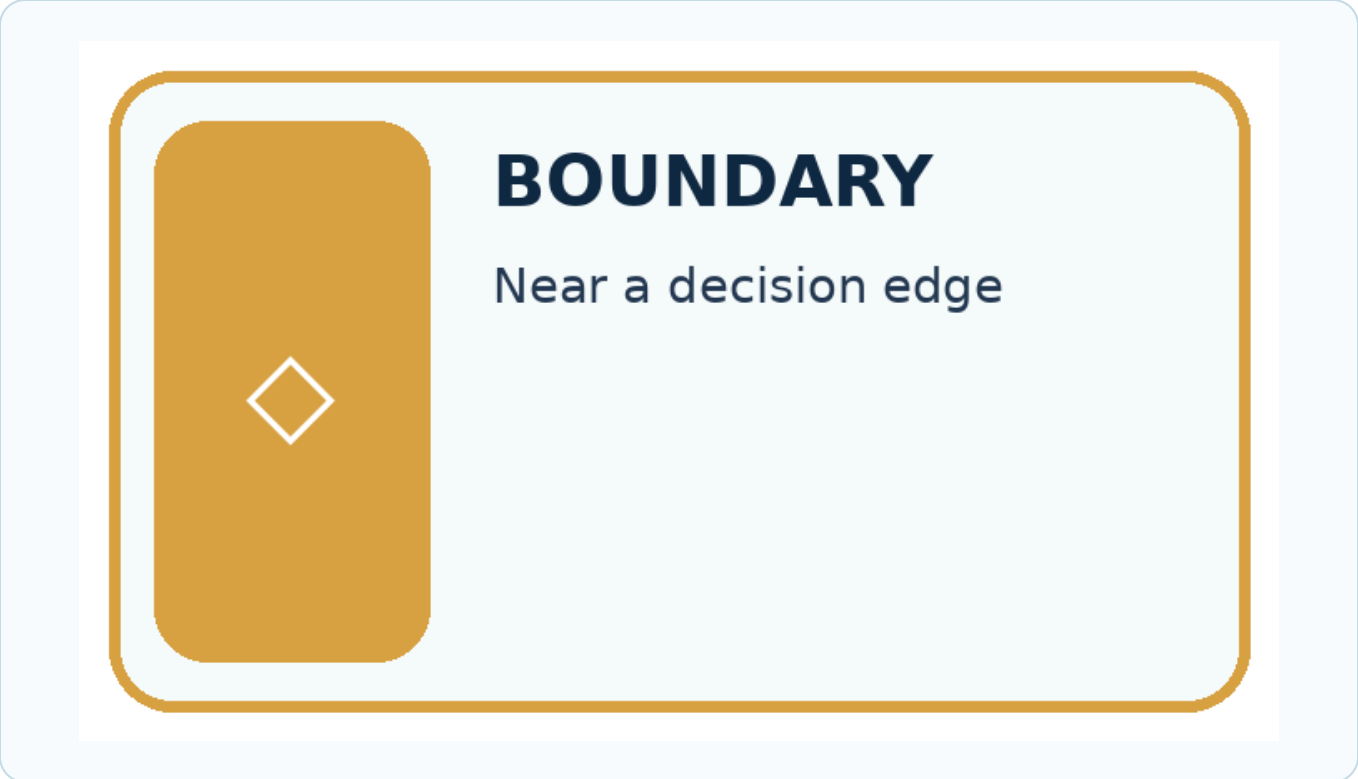
Compare permitted reads and denied operations

> A useful purpose does not expand the granted scope.

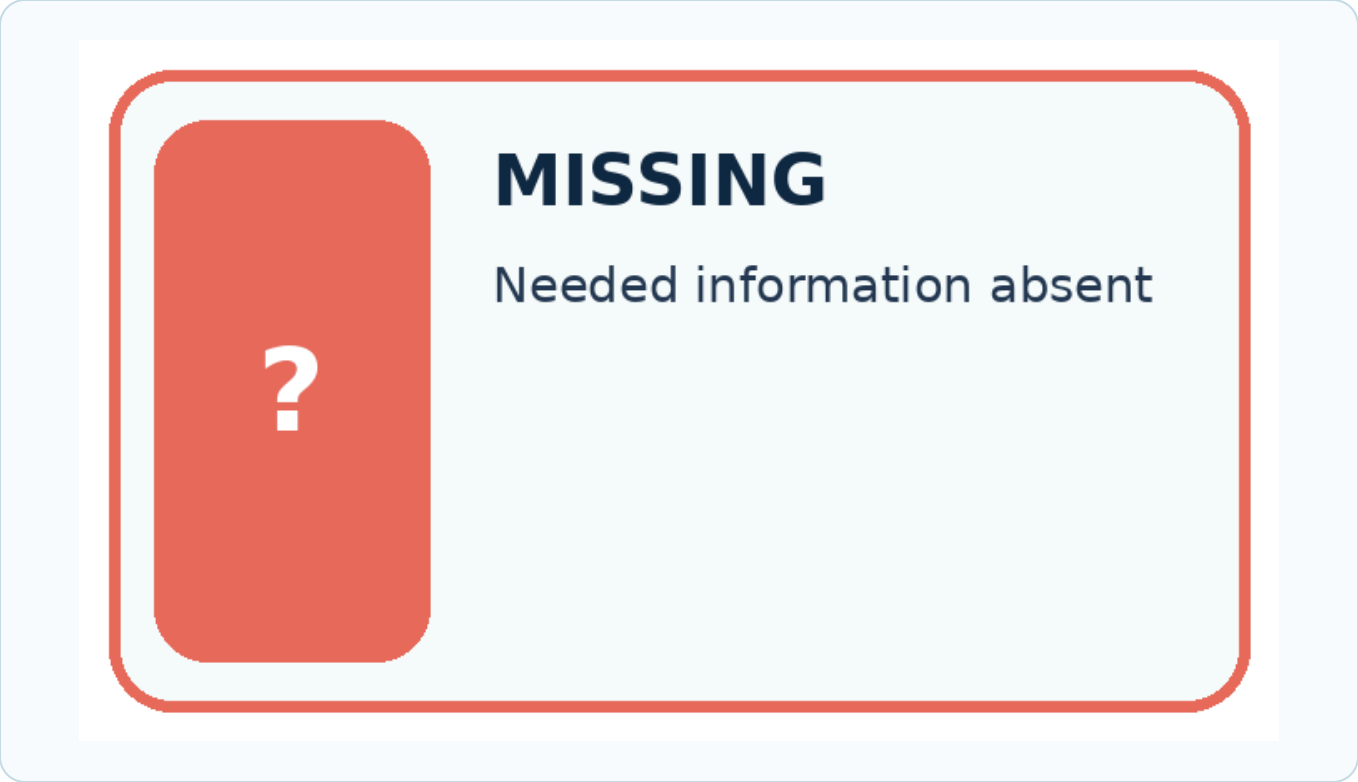
Four pictures with a purpose



Normal case: predict the result and deciding evidence.



Boundary case: identify the exact limit.



Missing information: name what must be clarified.



Transfer case: explain which procedure still applies.

Choose a revealing case

- Which case is most likely to reveal a hidden assumption? Why?

> **Write or draw your reasoning and evidence.**

Predict the supplied changed case

- Change: The helper says it needs write R5 to correct an apparent typo.

▼ Check after predicting

Prediction: The write remains denied under the existing token.

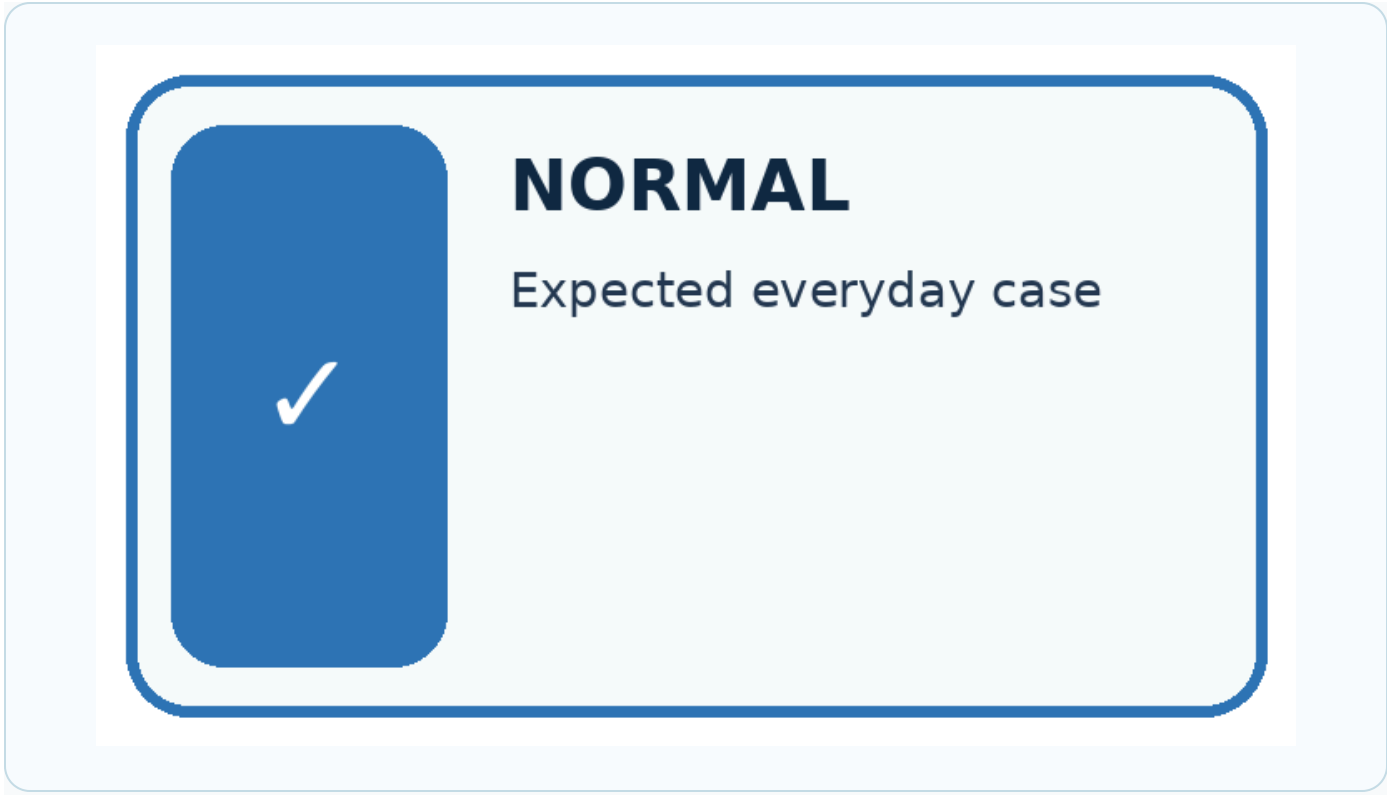
Reason: A useful purpose does not create an authorised operation; an authorised owner must review any scope change.

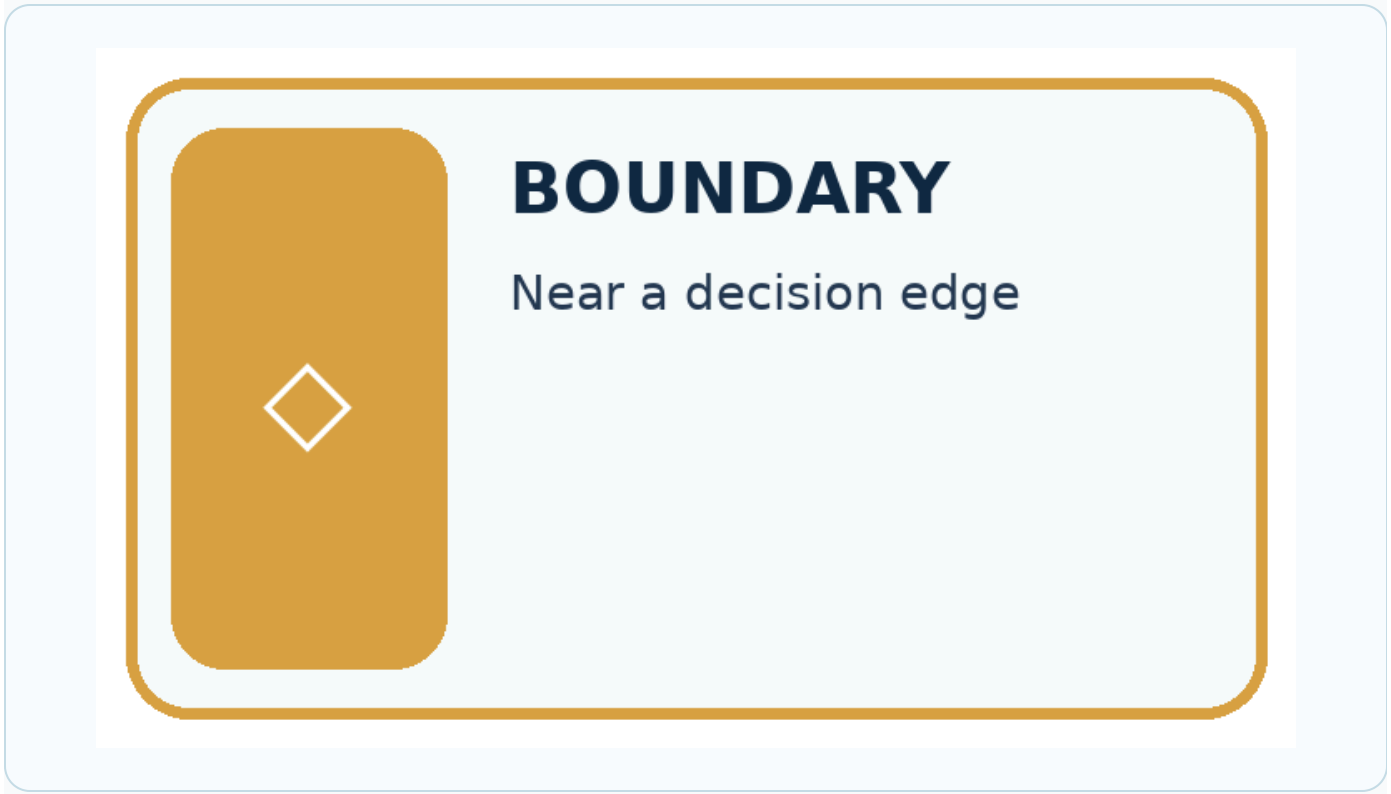
▼ Earlier wording, alternatives and picture transcripts

CASE GALLERY

Four Tests, Four Kinds of **Evidence**

A system is not understood until it survives more than one comfortable example.





NORMAL CASE: predict and name **evidence**. BOUNDARY CASE: predict and name **evidence**.





MISSING INFORMATION: predict and name **evidence**. TRANSFER CASE: predict and name **evidence**.

Change one thing in the pictured case

MAIN LESSON · SECTION 6

Compare a public-room policy and a separate catalogue token

> Keep the resources and operations for each policy distinct.

Try the reporting-assistant proposal

- Tool token permits lookup(public-room). A proposed call writes teacher notes.

▼ Check both scope violations

Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Read the separate catalogue token

A fictional catalogue helper receives a narrowly scoped tool token.

Token allows read on catalogue records R2 and R5 only. No write **permission** is granted.

Proposals: read R2; read R8; write R5. Generated text claims all are helpful.

Trace its three proposals



Follow the labelled picture with the matching explanation. Open the vector diagram

Read the picture one step at a time

STEP	WHAT HAPPENS AND WHY
1. Read token	Authorised operation is read; authorised objects are R2,R5.
2. Allowed call	read R2 matches both operation and object: allow.
3. Wrong object	read R8 fails object scope: deny.
4. Wrong operation	write R5 fails operation scope: deny even for an allowed record.

Match each pictured step to the supplied facts. This is a worked teaching case, not an independent assessment.

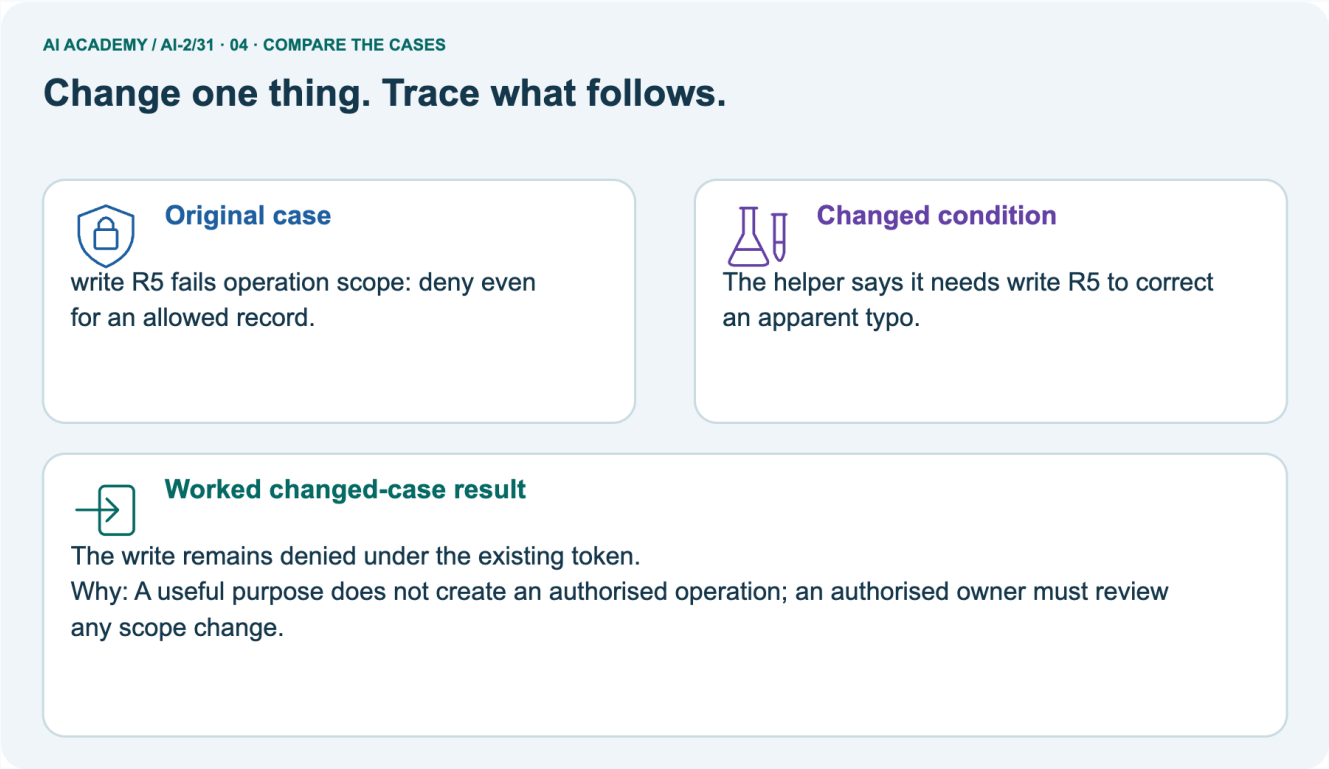
Permissions are concrete restrictions, not a confidence score or a general instruction to be useful. Each proposed call must match both dimensions before it happens.

A request written inside catalogue text cannot enlarge the token's authority. Denial should preserve the proposed action and reason without executing the disallowed mutation.

Predict the proposed typo correction

- Change one thing: The helper says it needs write R5 to correct an apparent typo. Predict the result before checking the explanation. What remains the same?

▼ Check after predicting



Follow the labelled picture with the matching explanation. Open the vector diagram

Keep permission and correctness separate

- **Permission** checks do not establish that a read result is trustworthy or that an allowed action is factually correct.

- Read the labelled picture: Which proposal is allowed, and why is an authorised object alone insufficient?

▼ Privacy extension · A hidden menu is not enforcement

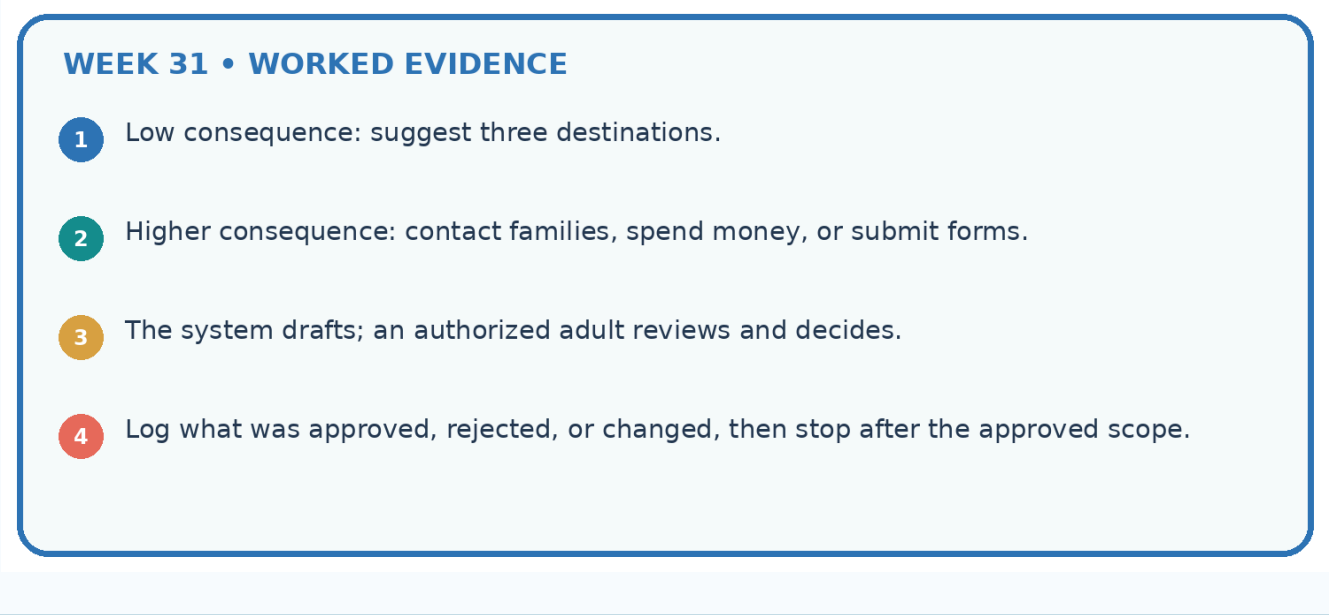
> **If a student manually requests the review endpoint, should hiding its menu link be enough?**

▼ Earlier wording, alternatives and picture transcripts

WORKED **EVIDENCE**

Reason Step by Step

Predict first. Then check each step. A correct answer without visible reasoning is incomplete **evidence**.



1. Low **consequence**: suggest three destinations.

2. Higher **consequence**: contact families, spend money, or submit forms.

3. The system drafts; an authorized adult reviews and decides.

4. Log what was approved, rejected, or changed, then stop after the approved scope.

Recalculate, retrace, or restate the reasoning in your own representation:

> **Write or draw your reasoning and evidence.**

CHECK Did the **evidence** answer the exact question? Did the total, path, or source record stay consistent?

A closer explanation

Compare the intermediate **evidence** with the final statement. Explain why each number or decision follows from the stated **input**s.

The conclusion belongs to this scenario and procedure; changing the **input**s, evaluation population or authority can change what it establishes. Retain the raw record so a later revision can be compared honestly.

Apply the connected idea: Privacy and least privilege

Learn from the worked case

Cover the result before checking it. Say what is given, choose the procedure, and follow one step at a time. Then uncover the result and explain your first mismatch. Ask why a step is allowed, not only what number it produces.

A pictorial worked case: Permissions and Human Review

The facts we will use



Follow the labelled picture with the matching explanation. Open the vector diagram

Why this result follows

What this example does not establish

MAIN LESSON · SECTION 7

Find the missing scope check

> Test actor, operation and object before carrying out a proposal.

Repair the authorised-object argument

Claim to repair: R5 is an authorised record, so writing R5 is allowed. The catalogue token permits read on R2 and R5 only. write R5 fails the operation check; read R8 fails the object check; only read R2 matches both. Neither generated confidence nor a request embedded in retrieved text expands that token. A review proposal can request a separately authorised scope change, but the denied call remains unexecuted until that change actually exists.

Propose a revealing permission test

> **Exit: propose one revealing change to the worked scenario. State the expected outcome and the evidence that would make you revise your explanation.**

▼ Earlier wording, alternatives and picture transcripts

ERROR DETECTIVE

Compare → Diagnose → Repair

Do not patch the answer. Find the earliest unsupported assumption, wrong step, or weak **evidence**.

!

COMPARE • DIAGNOSE

Weak idea: If an action is convenient, the system should receive permission automatically. Strong move: locate evidence, change one cause, and retest.

Evidence record	Expected	Actual	Likely cause / next test
normal case	works		
boundary case	stated rule		
missing input	safe response		
fresh transfer	generalizes		

Repair one cause. Why is this repair better than changing several things?

> **Write or draw your reasoning and evidence.**

A closer explanation

Complete the supported workbook tasks before attempting W4 independently. Record any hints or help used. After feedback, use the teacher's fresh retry rather than copying the earlier answer.

For a project, select a relevant new case, predict the outcome from the declared rule and preserve the result alongside any revision.

Apply the connected idea: Privacy and least privilege

Retention must be tied to a purpose and school policy rather than a guessed universal number of days. Identify who can correct or delete records and avoid keeping raw responses indefinitely just because storage is available.

> **Does the allowed function alone prove an app is secure?**

MAIN LESSON · SECTION 8

Practise the permission trace with less help

> A generated plan is not a source of additional authority.

State the authority boundary

A generated plan cannot expand the token or actor scope.

Complete main W2

Practise with less help: Trace the worked case

Use workbook W2 for the connected example "**Least privilege** and tool scopes". First fill the **input** and rule boxes. Try the middle steps before asking for a hint. After a hint, try the next step yourself.

Plan	Do	Check
What is given? Which rule or procedure applies?	Record each intermediate step.	Does the result follow? What remains unknown?

Repair a claim before discussion

- Use the worked case for **Least privilege** and tool scopes. Proposed explanation: “The worked result establishes every future case”. Decide whether this explanation is supported.

  Point to the step or supplied fact that decides; explain your repair if needed.

- Answer on your own before discussion. If you are unsure, say which step you need help with.

Check your reasoning

Explain the catalogue picture

- Which proposal is allowed, and why is an authorised object alone insufficient?

Explain the picture

> **My explanation using a pictured step and the given facts**

Keep the independent task separate

This is supported practice. Keep the separately named independent case for an attempt before feedback.

▼ **Privacy extension · Minimise fields and trace the role policy**

A form asks for names, birthdays and comments to count activity preferences. Remove fields not needed for the purpose.

Aggregated counts can still expose information in very small groups; choose reporting rules with the responsible teacher.

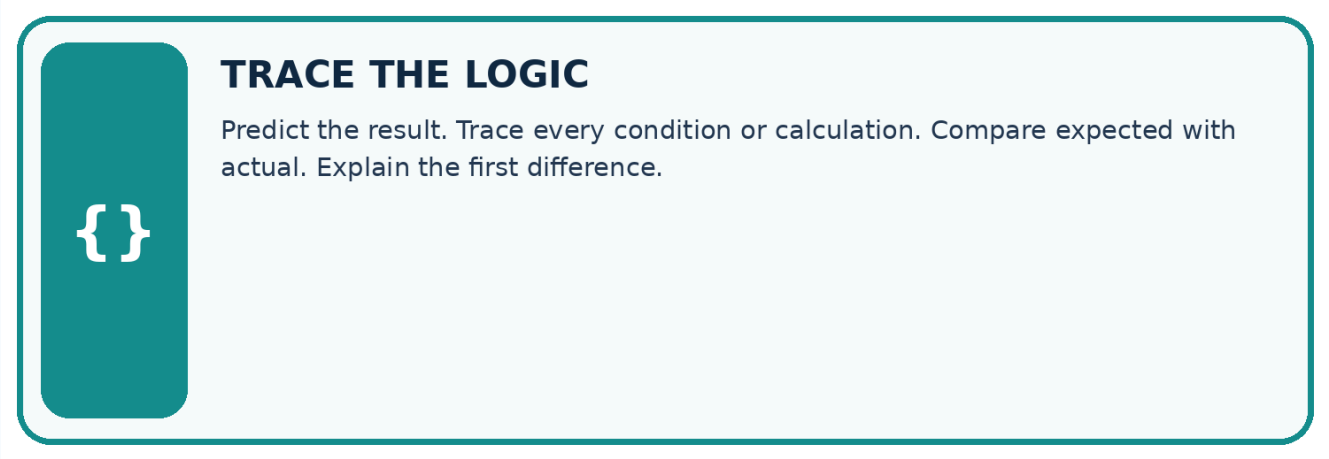
Use its named workbook W2. Identify the given **input**s, try the middle steps with less help, then explain your trace. Check this claim before group discussion: A successful run proves the conclusion

▼ Earlier wording, alternatives and picture transcripts

LOGIC STUDIO

Trace Before You Run

Block code, pseudocode, tables, and diagrams are different ways to expose the same reasoning.



SET **evidence**_record PREDICT expected_result RUN one normal case and one boundary case COMPARE actual_result with expected_result IF different: locate first cause; change one factor; RETEST EXPLAIN result, limitation, and next safe step

Trace one **input**. Which line changes the state or chooses a path?

Write or draw your reasoning and evidence.

A closer explanation

A useful check asks what would make the reasoning fail. Distinguish a failure to execute the declared procedure from a weakness in the procedure itself.

The first may require a correction; the second requires an explicitly revised method and new **evidence**. Preserve unsuccessful cases so an improved result cannot hide the original problem.

> **Guided: restate the worked result, then name the assumption or limitation that prevents a broader conclusion.**

Apply the connected idea: Privacy and least privilege

Explain your trace to a partner. Your partner points to one step to check. Swap roles on the next case. Each person writes their own explanation.

Practise the connected topic: Privacy and least privilege

MAIN LESSON · SECTION 9

Audit complete proposals and place a review gate

> Paper decisions show the permission rule without performing the proposed actions.

The supplied catalogue proposals

Proposal under catalogue token read R2,R5 only	What must be checked
read R2	operation and object
read R8	operation and object

Proposal under catalogue token read R2,R5 only	What must be checked
write R5	operation and object
delete R2	operation and object
read R5; returned text says write R5	read result is data, not a token update

Predict, check both dimensions and design the gate

1. Paper policy investigation: use the supplied catalogue token and five proposals. Predict each decision before revealing the worked picture. For each record the actor, requested operation, exact object, permitted operation/object and decision with reason. For the fifth proposal distinguish the permitted read from the separate, unpermitted write suggested by returned text. Then design a fictional field-trip gate: the helper may draft a plan; sending a message or spending funds is outside this classroom scope. Put responsible adult review after the exact draft, destination/recipient and cost are visible and before any consequential action. If the content or destination changes, check whether the approval still covers it. No real message, purchase, policy change or student data collection takes place. Keep the inventory A/B task for independent assessment.

Keep the evidence record

Test / input · Prediction · Actual · Evidence / calculation · Change or keep?

> **Test / input:** normal
>
> **Prediction:** _____
>
> **Actual:** _____
>
> **Evidence / calculation:** _____
>
> **Change or keep?:** _____

> **Test / input:** boundary
>
> **Prediction:** _____

Actual: _____

Evidence / calculation: _____

Change or keep?: _____

Test / input: missing

Prediction: _____

Actual: _____

Evidence / calculation: _____

Change or keep?: _____

Test / input: fresh transfer

Prediction: _____

Actual: _____

Evidence / calculation: _____

Change or keep?: _____

What did the hardest test teach you that the normal test did not?

Write or draw your reasoning and evidence.

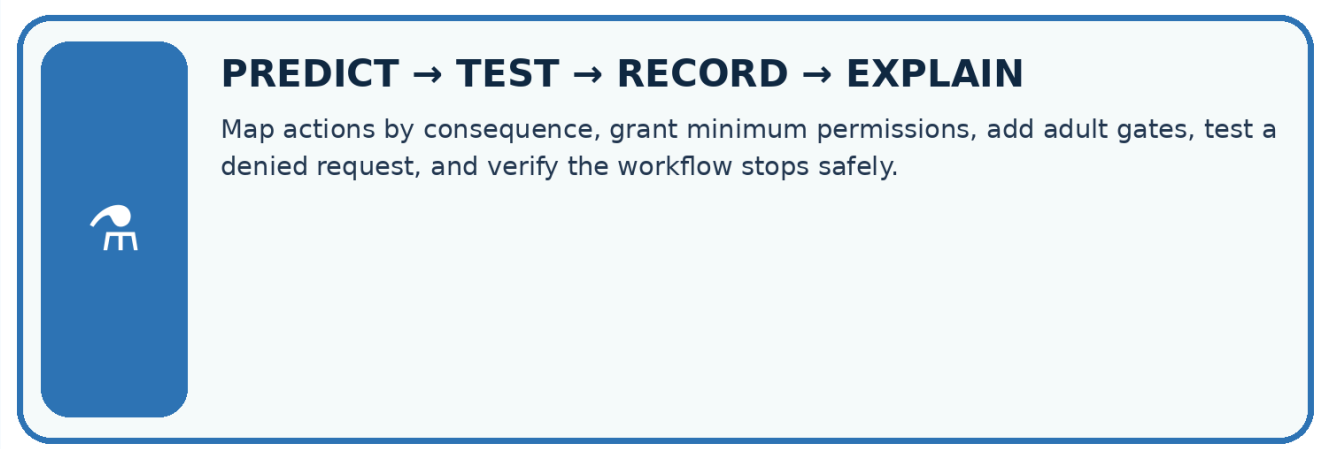
Before trying: what do I expect, and why? While trying: which step could first go wrong? Afterwards: what did I actually observe, and what should change? Keep “not run” if you only traced the procedure.

▼ **Earlier wording, alternatives and picture transcripts**

EVIDENCE LAB

Predict → Test → Record → Explain

Keep expected and actual results separate. Surprises are useful data when recorded honestly.



Audit the five supplied catalogue proposals under read R2/R5 only, then draw a fictional draft→adult review→permitted-action gate. Check exact content and destination. All decisions are paper simulations; do not execute messages, edits or purchases.

Plan → try → check

MAIN LESSON · SECTION 14

Try alone: decide the fresh inventory calls

> Check operation and object for each proposal.

The independent policy and scope

Scope allows read inventory items A, B. Calls read A, read C, write B. Decide.

For the independent inventory task, use only its stated read scope on A and B; it is a separate policy from both worked examples. Assume the caller holds that trusted scope for this paper check. Judge each call before execution, and do not infer correctness of a returned record from permission alone.

Your first attempt and help record

My independent explanation, trace and limits

Attempt this case before feedback. Record any help. Earlier examples below are further practice; a case already practised with feedback cannot establish fresh transfer.

Your teacher has the independent answer and scoring criteria. Complete the matching workbook week to keep your practice **evidence** together.

Use feedback after attempting

Attempt the independent case before hints. Record whether you worked alone, used a hint or followed a model. After feedback, fix the first unsupported step and explain why it changed.

A later check uses a changed case, not a copied answer.

▼ **Earlier wording, alternatives and picture transcripts**

Independent case: Apply a new case independently

Week 31 Independent application

Close the worked explanation. Apply the idea to this different question without copying.

A teacher allows a tool to draft a message but forbids sending. The draft is correct. May the agent send it? Explain the boundary.

My answer, with a trace, calculation or supporting **evidence**

Write or draw your reasoning and evidence.

Create and test

Change one relevant detail. Predict the result before testing. Include a boundary or missing-information case when it helps reveal a limit.

My changed **input** and expected result

> **Write or draw your reasoning and evidence.**

Connect to your project

The recommender may suggest and explain; people decide, borrow, purchase, or share data.

The **evidence** I will keep

> **Write or draw your reasoning and evidence.**

Transfer practice from the original programme

A teacher approves posting version 1 to a class board. The assistant changes the text and destination to a public board. Does the old approval cover the new action? Define what must be reviewed.

> **Explain the mechanism, evidence and one limit.**

Use feedback to improve

MAIN LESSON · SECTION 11

Keep recommendation, review and execution distinct

> An accurate draft does not grant publication permission.

This week’s concrete project contribution

Give the recommender only the read operations and specific catalogue objects it needs. Store a proposed edit or publication separately from an executed action. The responsible owner reviews exact content, destination and scope before any scope change or external action. Keep evidence checks separate: a permitted read can still return incorrect or irrelevant data. For the privacy extension, use invented category counts and purpose-limited role/action cards rather than real student records.

Keep the checkpoint and human choice

THIS WEEK’S CHECKPOINT The recommender may suggest and explain; people decide, borrow, purchase, or share data.

SYSTEM MAP Reader need → allowed **input**s → transparent rule or score → ranked candidates → explanation → test record → **human decision**

What will you add, change, or verify in the project this week?

> **Write or draw your reasoning and evidence.**

What should remain under **human control**?

Write or draw your reasoning and evidence.

RESPONSIBLE DESIGN Collect only necessary information. Show uncertainty and limits. Never confuse a ranking with a fact about a person.

Record the permission milestone

Give the recommender read-only access wherever sufficient, and require explicit owner review for catalogue edits or publication.

▼ Earlier wording, alternatives and picture transcripts

CUMULATIVE PROJECT

Transparent Book Recommender

Every week adds one inspectable piece. The system must show how it reached a result.



Evidence for your project

Finish: identify the authorised action and the missing authority

> State the evidence behind the permission decision.

Explain without notes

- Close your notes. Explain this goal in your own words: Explain the **mechanism** and terminology of **least privilege** and tool scopes

> **My deciding step, evidence and one remaining question**

Plan a changed-case return

If you are unsure, return to the worked picture and explain one arrow. If you are ready, change an **input** or assumption and justify your **prediction**.

Save your workbook **evidence**. At the next review, try a different case before opening your old answer.

Reference bank and extra practice

Choose the reference that helps your next step.

▼ **Reference · Words for the main lesson and extension**

REFERENCE · SECTION 5

Reference · Words for the main lesson and extension

> Use each word with a concrete record or calculation.

Core words

Word	My own example	Not this / boundary
permission	Authorisation to perform a specified action on specified information or resources.	
approval gate	A point where a specified action must wait for explicit authorisation.	
consequence	An outcome or effect of a decision, including who benefits or is harmed.	
least privilege	Giving a user or system only the permissions needed for its authorised task.	

Main explanation terms

Word	Meaning
Capability	A scoped permission to perform an operation
Resource scope	The specific records an operation may address

Extension terms

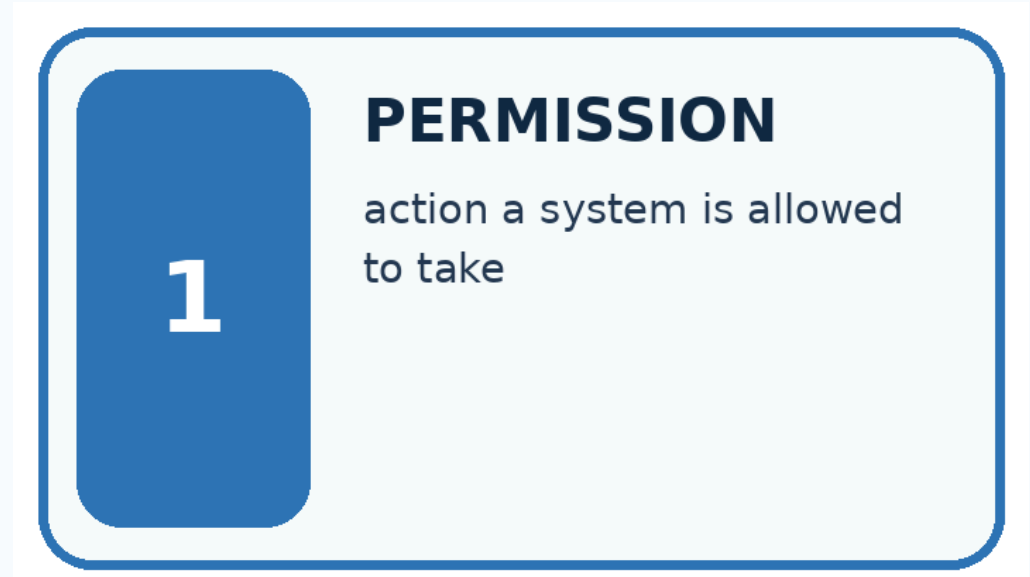
Term	Meaning
Data minimization	Keeping only data needed for the stated purpose
Least privilege	Giving a role only the access it needs
Retention	How long data is kept
Authorization	Permission to perform a particular action

▼ Earlier wording, alternatives and picture transcripts

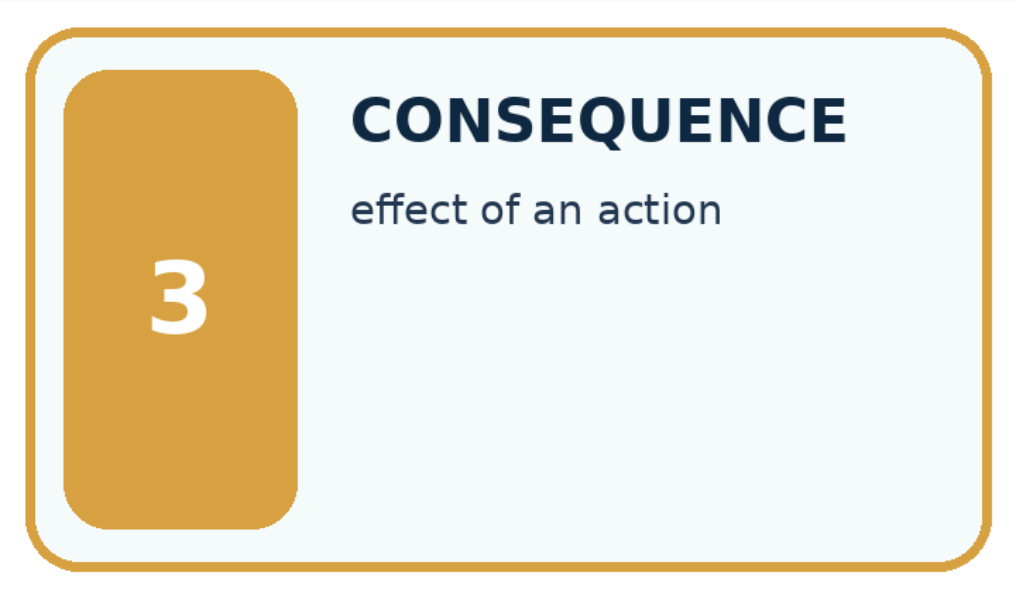
VOCABULARY LAB

Words You Can Use to Reason

A definition matters when you can recognize the idea, use it, and contrast it with a near-miss.




2
APPROVAL GATE
pause requiring authorized human choice


3
CONSEQUENCE
effect of an action



Words used in the closer explanation

Terms for Privacy and least privilege

▼ **Extra challenge · Choose a stronger explanation**

REFERENCE · SECTION 10

Extra challenge · Choose a stronger explanation

> Choose the next useful challenge rather than repeating the ladder.

Thinking ladder

- 1 • NAME: Define the concept without repeating the textbook.
- 2 • TRACE: Show the information, state, branch, calculation, or **evidence** path.
- 3 • APPLY: Solve a different example independently.

- 4 • CHALLENGE: Find a boundary case, counterexample, or unfair outcome.
- 5 • EXPLAIN LIMITS: Say when the result should not be trusted or used alone.
- My strongest **evidence** of independent understanding:

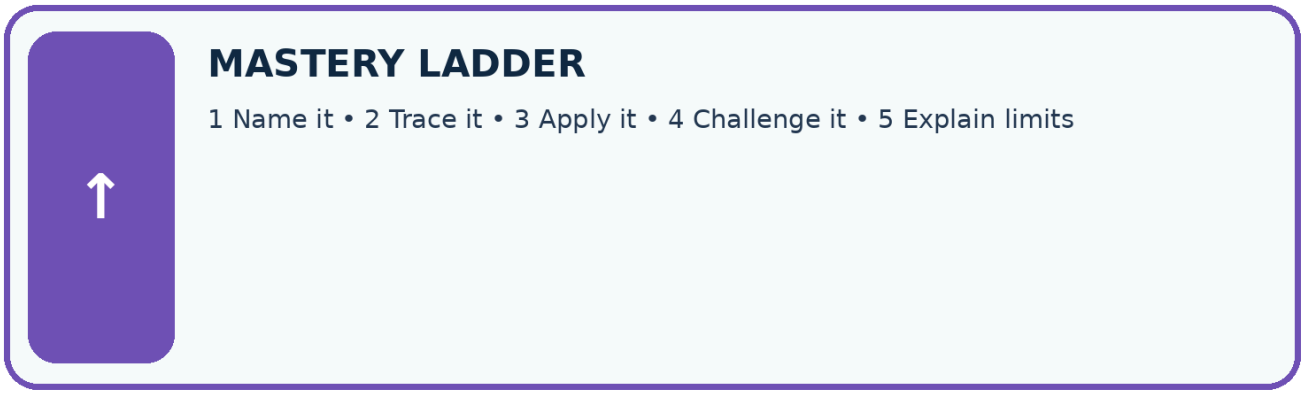
Write or draw your reasoning and evidence.

▼ Earlier wording, alternatives and picture transcripts

MASTERY

From Knowing the Word to Owning the Idea

Move upward only when you can produce **evidence** without copying the worked example.



▼ Reference · Check your explanation

Reference · Check your explanation

> Use after practice; Decide inventory calls independently is the selected independent task.

Evidence and limits

- 1. My fresh example, trace, calculation, or design:
- 2. My **evidence** that it works (include a boundary or missing-data case):
- 3. One limitation, fairness concern, or situation needing human review:

> **Write or draw your reasoning and evidence.**

> **Write or draw your reasoning and evidence.**

> **Write or draw your reasoning and evidence.**

Self-check

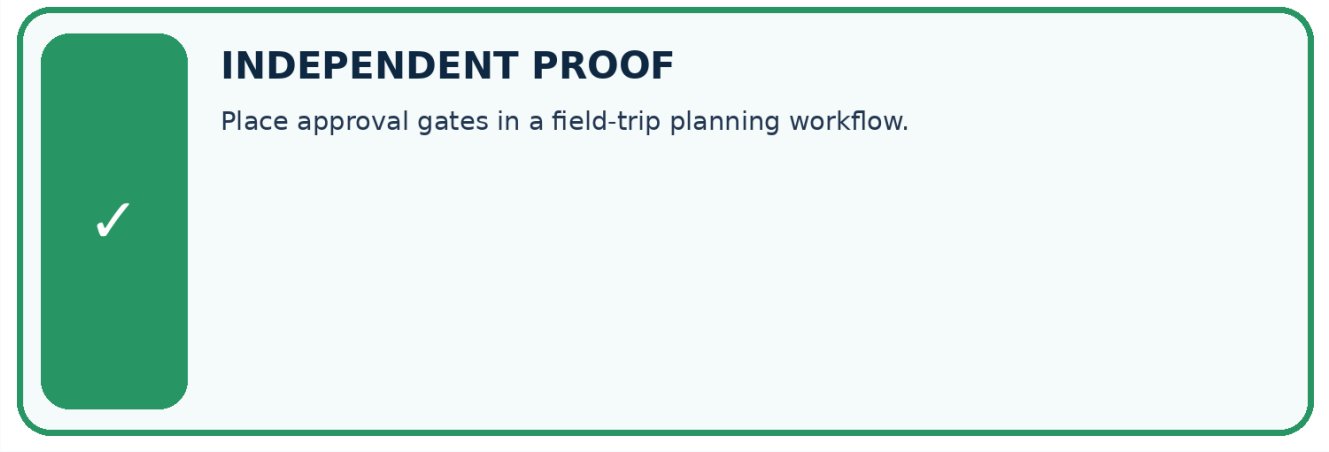
SELF-CHECK ☐ I explained the **mechanism** ☐ I used **evidence** ☐ I tested a fresh case ☐ I named a limitation ☐ I can answer 'why?'

▼ Earlier wording, alternatives and picture transcripts

INDEPENDENT MASTERY PROOF

Checklist for this week’s explanation

Use after practice. Decide inventory calls independently is the selected independent task.



Require the permitted operation and object for each call; a generated plan cannot expand authority.

▼ Extra practice · The earlier complete case

REFERENCE · SECTION 13

Extra practice · The earlier complete case

> Try the question before opening the worked explanation.

Question and given facts

Posting a recommendation requires teacher review.

Place the **approval gate**.

Your explanation

- Which detail supports the answer, and why does it matter?

Write or draw your reasoning and evidence.

▼ Check after trying

After draft and **evidence** are visible, before posting; include content and destination. No approval means no post.

Evidence or stage	Value or result
Draft	Show recommendation content
Evidence	Show support and destination
Teacher	Review and explicitly approve
Post	Proceed only with approval

▼ Earlier wording, alternatives and picture transcripts

Week 31 Worked case

Use the supplied details to practise the weekly concept before attempting the independent question. This case extends the illustrated lesson.

The situation

The question

Worked explanation

Explain it in your own words

Trace the supplied case visually

Put approval after evidence and before action

Posting a recommendation requires teacher review.

Place the **approval gate**.

After draft and **evidence** are visible, before posting; include content and destination. No approval means no post.

▼ **Reference · Earlier checklist**

REFERENCE · SECTION 15

Reference · Earlier checklist

> Use when it helps inspect the evidence.

Checklist and first prediction

By the end, I can	How I will show it
Explain the mechanism and terminology of least privilege and tool scopes	Explain the deciding step, show a trace or test, and state one limit.
Apply the stated procedure to a new case with a traceable result	Explain the deciding step, show a trace or test, and state one limit.
Identify an assumption or limitation and design a revealing follow-up	Explain the deciding step, show a trace or test, and state one limit.

Remember → watch and explain → try with help → investigate → try independently → keep project **evidence**. Your teacher may spread this lesson across several classes.

Keep your first **prediction**. Compare it with what the **evidence** shows and explain any change.

▼ Earlier wording, alternatives and picture transcripts

Start with this question: A fictional catalogue helper receives a narrowly scoped tool token.

▼ Extra practice · Pictures, feedback and repair

REFERENCE · SECTION 17

Extra practice · Pictures, feedback and repair

> Try before opening feedback; keep the selected independent task separate.

First supported question

- A fictional catalogue helper receives a narrowly scoped tool token.
- Which labelled step matches this detail? write R5 fails operation scope: deny even for an allowed record.
- 1. Wrong operation
- 2. Read token
- 3. Wrong object
- 4. Allowed call

- Hint if needed: Read the steps in the pictorial case. Match the supplied detail to the stage that performs or records it.

Practice 1: explain the deciding evidence

> **My selected conclusion, deciding fact and explanation**

<details>
<summary>Check after trying</summary>

After your attempt, compare with the supported explanation: Wrong operation write R5 fails operation scope: deny even for an allowed record.

Permissions are concrete restrictions, not a confidence score or a general instruction to be useful. Each proposed call must match both dimensions before it happens.

A request written inside catalogue text cannot enlarge the token's authority. Denial should preserve the proposed action and reason without executing the disallowed mutation.
</details>

Changed-case question

- Changed-case practice: The helper says it needs write R5 to correct an apparent typo. Which conclusion is supported by the supplied facts?

- 1. We can decide the result without examining the changed **input** or the procedure.

- 2. This one example guarantees correct results for every future **input**.

- 3. The write remains denied under the existing token.

- Hint if needed: Use the changed condition and the deciding step in the pictorial trace. The answer must say what follows from those facts.

Practice 2: explain the deciding evidence

My selected conclusion, deciding fact and explanation

▼ **Check changed case**

After your attempt, compare with the supported explanation: The write remains denied under the existing token. A useful purpose does not create an authorised operation; an authorised owner must review any scope change.

Repair and keep evidence

Review Agents and Tools (ai-2/30). Goal: Explain the **mechanism** and terminology of state machines for bounded agents. Short practice: Can the assistant accept Trace B because its final state is done?.

Return to this week and explain what you changed.

Review Prompt Experiments (ai-2/28). Goal: Explain the **mechanism** and terminology of controlled prompt experiments. Short practice: Name the case P passes and Q fails, and explain why it matters..

Return to this week and explain what you changed.

Review Text as Pieces (ai-2/25). Goal: Encode and decode text under an explicit toy vocabulary. Short practice: Why is the unknown ! at position 10 rather than position 9?. Return to this week and explain what you changed.

The browser lab lets you edit the supported Python examples already included in this lesson. Predict first, run, inspect the actual **output** or error, change one **input**, then run again.

Keep code, **prediction**s, actual results and a reasoned revision together. On paper, label your result as a trace rather than an execution.

Use Download completed work in the hosted lesson to export your answers, reflections, practice feedback and code-run **evidence**. Open the HTML copy to read or print it.

Drafts stay in this browser when storage is available; clear drafts on a shared device.

▼ Earlier wording, alternatives and picture transcripts

Use this supported practice once, in the browser or on paper. Keep the reserved independent assessment for a separate first attempt before teacher feedback.

Repair a missing building block

Predict, run and debug

Keep your completed work

▼ Reference · The six-picture journey

REFERENCE · SECTION 18

Reference · The six-picture journey

> Revisit the picture that serves the current question.

01. Permissions and Human Review: the case



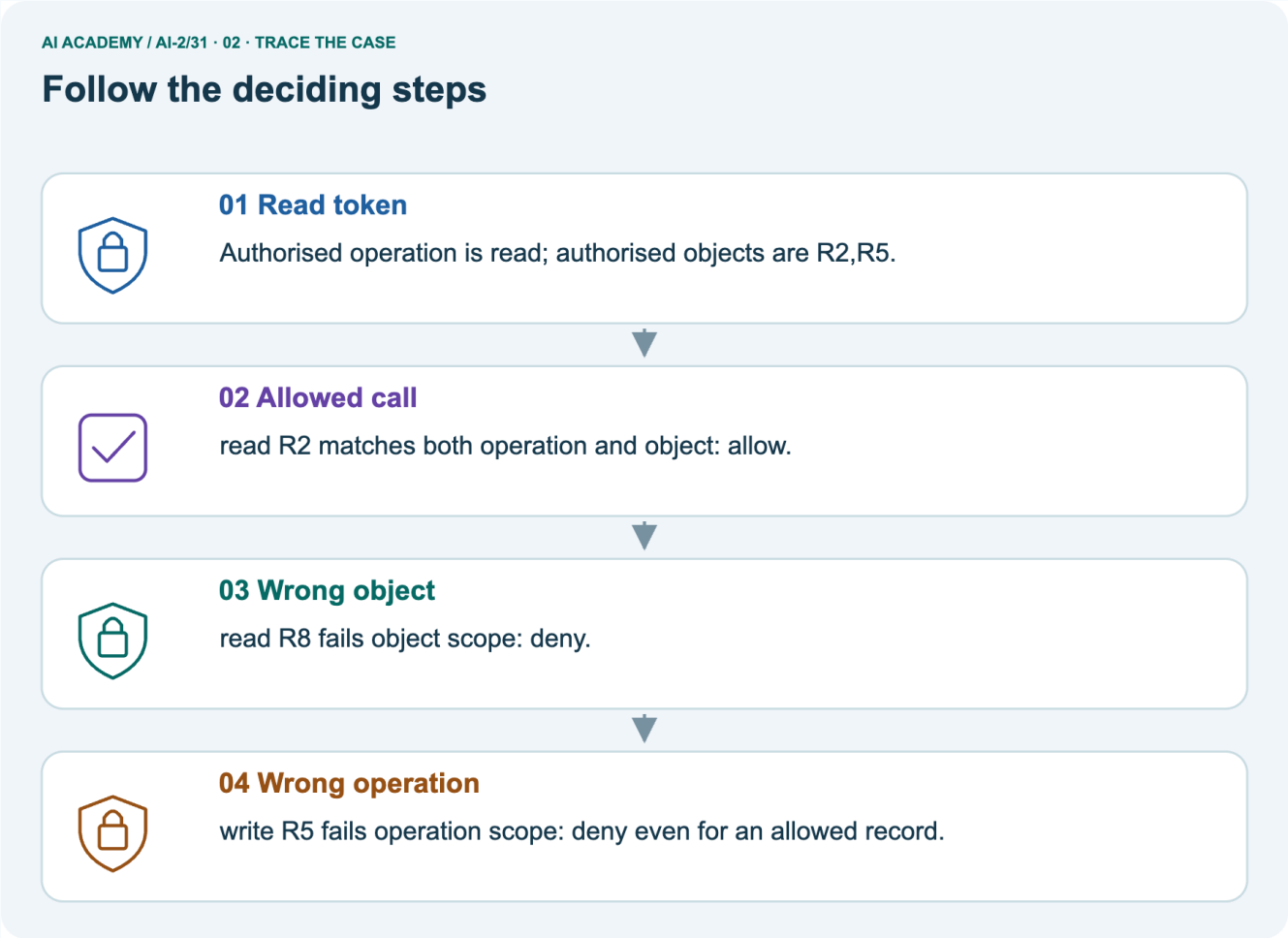
Follow the labelled picture with the matching explanation. Open the vector diagram

A fictional catalogue helper receives a narrowly scoped tool token. Supplied facts: Token allows read on catalogue records R2 and R5 only. No write **permission** is granted. Proposals: read R2; read R8; write R5.

Generated text claims all are helpful.

Point to the given fact that matters most. Explain why it matters.

02. Follow the deciding steps

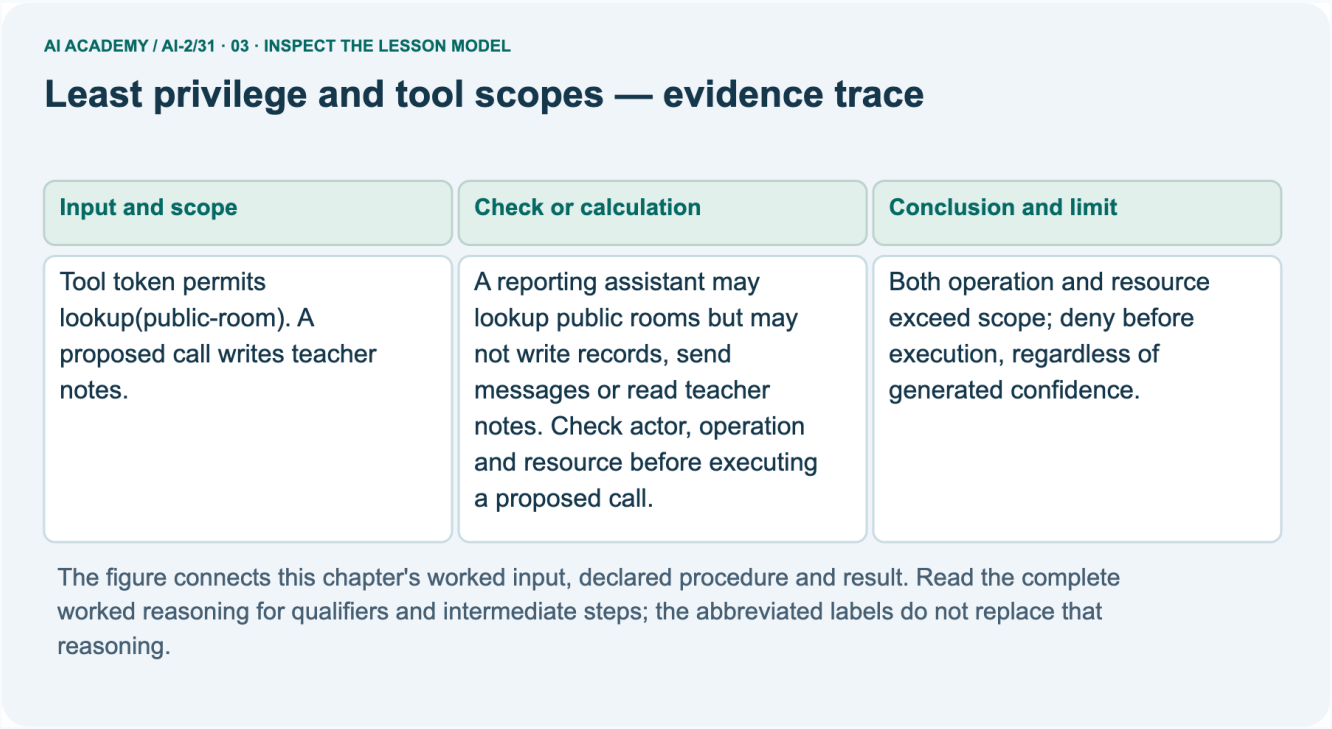


Follow the labelled picture with the matching explanation. Open the vector diagram

Read token: Authorised operation is read; authorised objects are R2,R5. → Allowed call: read R2 matches both operation and object: allow. → Wrong object: read R8 fails object scope: deny. → Wrong operation: write R5 fails operation scope: deny even for an allowed record.

Point to each numbered stage and explain which recorded **input** it uses.

03. Least privilege and tool scopes — evidence trace



Follow the labelled picture with the matching explanation. Open the vector diagram

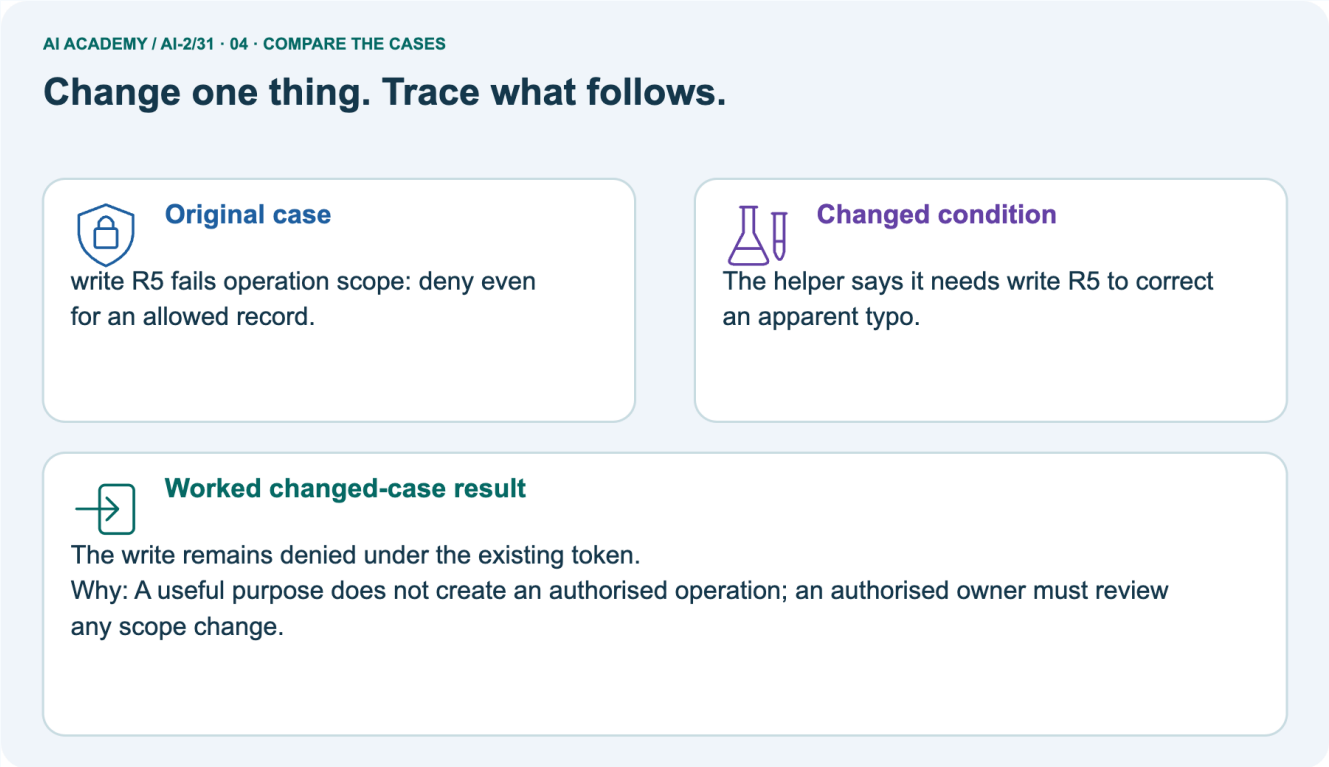
Least privilege and tool scopes — **evidence** trace. Tool token permits lookup(public-room).

A proposed call writes teacher notes. | A reporting assistant may lookup public rooms but may not write records, send messages or read teacher notes.

Check actor, operation and resource before executing a proposed call. | Both operation and resource exceed scope; deny before execution, regardless of generated confidence.

Read the labels and values. Explain the relationship the model shows.

04. Change one thing. Trace what follows.



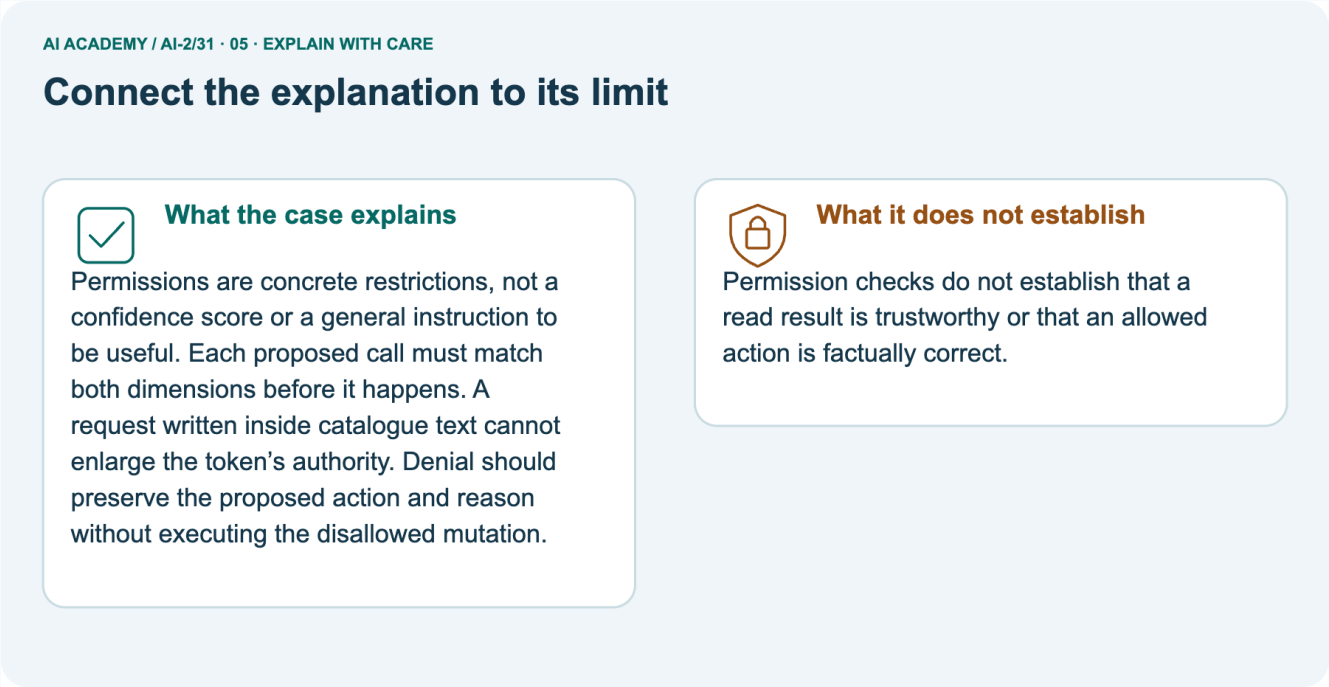
Follow the labelled picture with the matching explanation. Open the vector diagram

Original case: write R5 fails operation scope: deny even for an allowed record. Changed condition: The helper says it needs write R5 to correct an apparent typo.

Expected result: The write remains denied under the existing token. Reason: A useful purpose does not create an authorised operation; an authorised owner must review any scope change.

Predict before checking the worked changed-case result. Name what changed and what the supplied facts allow you to conclude.

05. Connect the explanation to its limit



Follow the labelled picture with the matching explanation. Open the vector diagram

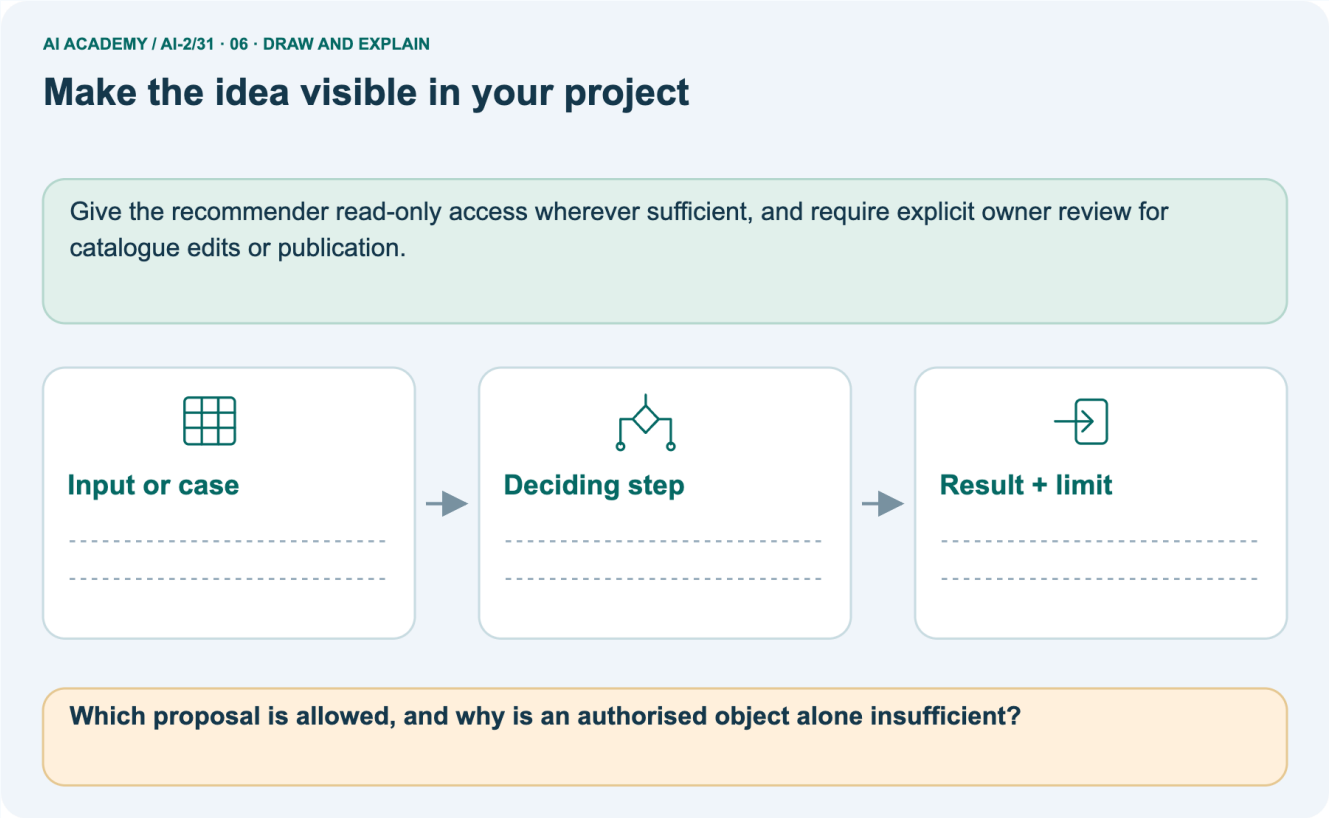
Permissions are concrete restrictions, not a confidence score or a general instruction to be useful. Each proposed call must match both dimensions before it happens.

A request written inside catalogue text cannot enlarge the token's authority. Denial should preserve the proposed action and reason without executing the disallowed mutation.

Limit: **Permission** checks do not establish that a read result is trustworthy or that an allowed action is factually correct.

Explain the case, then point to a limit on the claim.

06. Make the idea visible in your project



Follow the labelled picture with the matching explanation. Open the vector diagram

Give the recommender read-only access wherever sufficient, and require explicit owner review for catalogue edits or publication. Draw your **input**, deciding step, result and limit.

Supported question: Which proposal is allowed, and why is an authorised object alone insufficient?

Draw your project trace and justify the deciding step using **evidence**.

▼ Earlier wording, alternatives and picture transcripts

01. Permissions and Human Review: the case

02. Follow the deciding steps

03. Least privilege and tool scopes — evidence trace

04. Change one thing. Trace what follows.

05. Connect the explanation to its limit

06. Make the idea visible in your project

▼ Optional interactive practice and completed work

Save or print your responses for your portfolio. Progress and drafts on the hosted website stay in the current browser. Use only fictional or teacher-approved data.